

SITE SECURITY REPORT

Target: https://apple.com

Final URL: https://www.apple.com/

Status: 200 IP: 192.0.2.1

Scanned: 2026-10-01T06:21:28.719313+00:00

A

Security posture

This report evaluates observable HTTP/TLS/browser security configuration. It is not a penetration test.

6

Passed

2

Warnings

0

Failed

6

Info

Priority Findings

Severity	Category	Finding	Recommendation
MEDIUM	Cookies	Cookie 'geo' lacks Secure The cookie can potentially be sent over a non-HTTPS connection.	Add the Secure attribute to cookies that should only travel over HTTPS.
MEDIUM	Security Headers	Content-Security-Policy Potentially permissive CSP directives detected: unsafe-eval, unsafe-inline	Review CSP directives and remove unnecessary unsafe or wildcard sources.
LOW	Cookies	Cookie 'geo' lacks HttpOnly JavaScript can access this cookie through document.cookie.	Use HttpOnly for cookies that do not need client-side JavaScript access.
LOW	Cookies	Cookie 'geo' lacks SameSite No SameSite policy was declared.	Consider SameSite=Lax or SameSite=Strict where compatible.
LOW	Security Headers	CSP has no frame-ancestors directive Clickjacking protection may depend on another mechanism.	Consider frame-ancestors 'none' or an appropriate allowlist.
LOW	HTML / JavaScript	Inline JavaScript detected 5 inline script block(s) were found.	Prefer nonces/hashes with a strict CSP instead of broad unsafe-inline.
LOW	Security Headers	Permissions-Policy Permissions-Policy is missing.	Declare browser capabilities that the application does not need.
INFO	Cross-Origin Isolation	Cross-Origin-Opener-Policy not observed The site does not opt into a COOP policy on this response.	Consider COOP if your application benefits from cross-origin isolation.

Security Checks

Category	Check	Status	Observed value / detail
Security Headers	Strict-Transport-Security	PASS	max-age=31536000; includeSubdomains; preload
Security Headers	Content-Security-Policy	WARN	default-src 'self' blob: data: *.akamaized.net *.apple.com *.apple-mapkit.com *.cdn-apple.com *.organicfruitapps.com; child-src blob: mailto: embed.music.apple.com embed.podcasts.apple.com https://recyclingprogram.apple.com https://smb.apple.com https://nova.apple.com swdlp.apple.com www.apple.com www.instagram.com platform.twitter.com www.youtube-nocookie.com; img-src 'unsafe-inline' blob: data: *.apple.com *.apple-mapkit.com *.cdn-apple.com *.mzstatic.com; script-src 'unsafe-inline' 'unsafe-ev...
Security Headers	X-Content-Type-Options	PASS	nosniff

Category	Check	Status	Observed value / detail
Security Headers	X-Frame-Options	PASS	SAMEORIGIN
Security Headers	Referrer-Policy	PASS	no-referrer-when-downgrade
Security Headers	Permissions-Policy	WARN	Permissions-Policy is missing.
Cross-Origin Isolation	Cross-Origin-Opener-Policy	INFO	cross-origin-opener-policy is not present.
Cross-Origin Isolation	Cross-Origin-Resource-Policy	INFO	cross-origin-resource-policy is not present.
Cross-Origin Isolation	Cross-Origin-Embedder-Policy	INFO	cross-origin-embedder-policy is not present.
Information Disclosure	Server	INFO	Apple
CORS	Access-Control-Allow-Origin	INFO	No CORS allow-origin header was observed.
Caching	Cache-Control	INFO	max-age=0
TLS	TLS Protocol	PASS	TLSv1.3
TLS	Certificate Expiry	PASS	Dec 16 18:31:25 2026 GMT

Cookie Security

Name	Secure	HttpOnly	SameSite
geo	NO	NO	missing

TLS / DNS / HTML Observations

TLS

```
{
  "https": true,
  "version": "TLSv1.3",
  "cipher": "TLS_AES_256_GCM_SHA384",
  "certificate_subject": [
    [
      "businessCategory",
      "Private Organization"
    ],
    [
      "jurisdictionCountryName",
      "US"
    ],
    [
      "jurisdictionStateOrProvinceName",
      "California"
    ],
    [
      "serialNumber",
      "C0806592"
    ],
    [
      "countryName",
      "US"
    ],
    [
      "stateOrProvinceName",
      "California"
    ],
    [
      "localityName",
      "Cupertino"
    ],
    [
      "organizationName",
      "Apple Inc."
    ],
    [
      "commonName",
      "www.apple.com"
    ]
  ],
  "certificate_issuer": [
    [
      "countryName",
```

```
"US"
]
],
[
[
"organizationName",
"Apple Inc."
]
],
[
[
"commonName",
"Apple Public EV Server RSA CA 1 - G1"
]
]
],
"not_before": "Jul 2 22:11:57 2026 GMT",
"not_after": "Dec 16 18:31:25 2026 GMT",
"days_remaining": 76,
"san_count": 3
}
```

DNS

```
{
"hostname": "www.apple.com",
"a": [
"192.0.2.1"
],
"aaaa": []
}
```

HTML

```
{
"is_html": true,
"title": "Apple",
"scripts": 17,
"inline_scripts": 5,
"external_scripts": 12,
"external_script_urls": [
"/v/homepage/a/scripts/head.built.js",
"/api-www/global-elements/global-header/v1/assets/globalheader.umd.js",
"/metrics/ac-analytics/2.30.0/scripts/ac-analytics.js",
"/metrics/ac-analytics/2.30.0/scripts/auto-init.js",
"/ac/globalfooter/8/en_US/scripts/ac-globalfooter.built.js",
"/ac/localeswitcher/4/en_US/scripts/localeswitcher.built.js",
"/autopush/us/fam-gallery/scripts/endless-entertainment-gallery.built.js",
"/v/homepage/a/scripts/inline-media.built.js",
"/v/homepage/a/scripts/main.built.js",
"/v/homepage/a/scripts/homepage.built.js",
"/metrics/data-relay/1.2.0/scripts/data-relay.js",
"/metrics/data-relay/1.2.0/scripts/auto-relay.js"
],
"forms": 1,
"password_forms": 0,
"insecure_password_forms": [],
"mixed_content": [],
"iframes": 0,
"images": 101,
"links": 143
}
```

Redirect Chain

Status	From	To
301	https://apple.com/	https://www.apple.com/
200	https://www.apple.com/	https://www.apple.com/

Methodology note: This report is an independent passive configuration assessment. A PASS does not prove that an application is free of vulnerabilities, and a missing header does not necessarily mean the application is exploitable. Header recommendations should be reviewed against

the application's functionality and threat model.